securityholders.[837] Another commenter stated that this proposed requirement would be unnecessarily burdensome for covered institutions and that it could have negative consequences for clients, noting that there would be a risk that too much information could be overwhelming and lead to desensitization.[838]

Another commenter disagreed with the proposed requirement that a covered institution would have had to notify customers whose information was compromised unless the covered institution could determine that the event would not result in a risk of substantial harm or inconvenience for these individuals, suggesting instead that the standard be harmonized further with the Banking Agencies' Incident Response Guidance and with many state laws so as to require notification only if the covered institution affirmatively could find risk of harm.[839] This commenter stated that the proposed presumption of notification could lead to excessive and unnecessary notifications to consumers where a low likelihood of harm were present, which could result in consumers spending time and effort needlessly monitoring accounts or taking actions such as instituting a credit freeze, and simultaneously desensitize consumers to a notification for an actual breach where significant harm could result.[840]

After considering these comments, we have determined that the presumptions of notification should be included in the final amendments. On the one hand, we acknowledge, as commenters stated,[841] that unnecessary notifications could occur and negatively affect covered institutions and their customers as a result of these presumptions. Unnecessary notifications will

---

837 *See* Computershare Comment Letter.

838 *See* IAA Comment Letter 1.

839 *See* SIFMA Comment Letter 2.

840 *See* SIFMA Comment Letter 2.

841 *See supra* footnotes 834-840 and accompanying text.

result in costs for covered institutions, including the costs associated with notification such as administrative costs related to preparing and distributing notices as well as reputational costs, litigation risk, or diversion of resources identified by commenters. [842] More broadly, as stated by commenters,[843] unnecessary notification could reduce customers' responsiveness to data breach notices, for example by decreasing customers' ability to discern which notices require action. Unnecessary notification could also desensitize customers to notices, thereby leading to a decrease in the reputational costs of notification. This could decrease covered institutions' incentives to invest in customer information safeguards in order to avoid such reputational costs.[844] However, the risks of unnecessary notification reducing the benefits of the rule are mitigated by the fact that notification is not required in cases where the covered institution can determine, after a reasonable investigation, that there is no risk of substantial harm or inconvenience for the customers whose information has been compromised. In addition, in a change from the proposal, the final amendments explicitly provide that a covered institution need not provide notice to an individual whose sensitive customer information resides in the customer information system that was, or was reasonably likely to have been, accessed or used without authorization if the covered institution reasonably determines that this individual's sensitive customer information was not accessed or used without authorization.[845]

On the other hand, adopting these presumptions of notification will allow potentially affected customers to take appropriate mitigating actions. In support of the proposed

---

842 *Id*.

843 *See* IAA Comment Letter 1; SIFMA Comment Letter 2.

844 Estimates of certain costs related to notice issuance are discussed above. *See supra* footnote 833 and accompanying text.

845 *See* final rule 248.30(a)(4)(ii).

presumption of notification, another commenter stated that any risk that a presumption to notify individuals could lead to a volume of notices that would inure affected individuals to the notices and result in their not taking proactive action would be outweighed by the risk that individuals would not be notified at all and would not have the opportunity to decide for themselves whether to take action.[846] To support this statement, this commenter referenced a study stating that requiring a determination of misuse to trigger disclosure permits additional discretion to the breached entity which, coupled with the existence of a disclosure disincentive,[847] might bias an institution's investigation of a data leak and might lead to a conclusion that consumer notification was not required.[848] We agree with this commenter. In addition, as discussed above, allowing covered institutions to conduct a full investigation before determining whether customers need to be notified could significantly reduce the benefits of such notification, and thus of the final amendments, by delaying the notice.[849]

(5) Content and Method of Notice

The proposed amendments included a list of information that would have had to be included in a customer notice.[850] Many of these content requirements remain in the final amendments.[851] While some commenters agreed generally with the proposed notice content

---

846 *See* Better Markets Comment Letter.

847 *See supra* section IV.B.

848 *See* Better Markets Comment Letter, citing Paul M. Schwartz and Edward J. Janger, *Notification of Data Security Breaches*, 105 MICH. L. REV. 913, 939 (2007). In addition, a report cited by the same commenter discusses the frequency of notification and how it relates to specific notification trigger. The report links higher frequency of notification to a requirement that a government official participate in the determination that a data breach creates risk for the affected parties, and therefore that notification is required. *See* IRTC Data Breach Annual Report; *see also supra* footnote 518 and accompanying text.

849 *See supra* section II.A.3.a; *see also supra* section IV.D.1.b(2) for a discussion of the benefits of timely notification.

850 *See* proposed rule 248.30(b)(4)(iv).

851 *See* final rule 248.30(a)(4)(iv).

requirements,[852] other commenters disagreed with the proposed inclusion of some elements and stated that our analysis of these requirements in the Proposing Release was insufficient.[853] In response to these commenters, we conducted supplemental analysis of the frequency at which different items are required in existing state laws, and are including a supplemental analysis of the costs and benefits of each of the required elements vis-à-vis this baseline.[854]

The main benefit of requiring specific content to be included in the notice is to help ensure that customers residing in different states receive similar information when their information is compromised in the same breach. Because state law requirements differ in terms of required content, covered institutions may send different notices to different individuals.[855] The final amendments will help ensure that all customers receive a minimum of information regarding a given breach affecting their information and are therefore equally able to take appropriate mitigating actions.

The final amendments provide that the notice must include a description of the incident, including the information that was breached and the approximate date at which it occurred, as well as contact information where customers can inquire about the incident. In addition, the notice must include information on recommended actions affected customers can take. We expect that these required items will help customers take appropriate mitigating action to protect themselves from further effect of the breach. Including these elements might require some

---

852 *See, e.g.*, Better Markets Comment Letter.

853 *See, e.g.*, CAI Comment Letter.

854 *See supra* section IV.C.2.a(2).

855 *See* ICI Comment Letter 1 ("In discussing breach notices with our members, we understand it is not uncommon for their current breach response programs to include separate notification letters depending upon the state the individual resides in.").

covered institutions to modify their existing processes for notification, which will incur some costs.[856] We expect that these costs will be passed on to customers.

The first required item is a general description of the incident and the type of sensitive customer information that was or is reasonably believed to have been accessed or used without authorization.[857] We received no comment on this specific requirement. Obtaining this information is crucial for customers as it will allow them to assess the level of risk and to take appropriate mitigating actions. This will also allow them to avoid spending time and resources on mitigating actions related to information that was not affected by the breach. We expect that most covered institutions who already have notification processes already include this information, since 22 states require that the notice describe the type of information affected by the breach and 13 states require a description of the incident to be included.[858] As a result, we expect that the benefits will be the greatest for customers of institutions who do not operate nationally and operate only in states without such requirements. We estimate that there are approximately 51 million potential customers residing in the 38 states that do not require a description of the incident, and 35 million potential customers residing in the 29 states that do not require the type of customer information compromised to be included in the notice.[859] We expect the costs to be the highest for the covered institutions operating only in those states.

---

856 These costs are included in the policies and procedures costs discussed in section IV.D.1 above. As discussed below, we estimate that certain costs associated with developing and implementing policies and procedures to comply with the final amendments will be, on average, $15,445 per year per covered institution. This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $5,425 per year per covered institution. *See infra* section V.

857 *See* final rule 248.30(a)(4)(iv)(A).

858 *See supra* section IV.C.2.a(2).

859 *See supra* footnote 767.

The second item required by the final amendments is the date of the incident, the estimated date of the incident, or the date range within which the incident occurred, if the information is reasonably possible to determine at the time the notice is provided.[860] One commenter disagreed with this proposed requirement, stating that it would imply that covered institutions subject to both Regulation S-P and the Banking Agencies' Incident Response Guidance would have to revise their long-standing breach notices to add the information.[861] This commenter also stated that the Proposing Release did not detail a basis for this inclusion. Including the date of the breach, even if it is the approximate date, will provide useful information to the affected customers and help them make better decisions about the mitigating actions to take. In particular, customers could review their account statements back to the date where the breach happened.[862] An additional benefit of this inclusion will be to provide information to customers about how effectively a covered institution was able to detect and assess a breach. This will help reduce the information asymmetry about a covered institution's customer information safeguards and help customers be better informed when deciding which covered institutions to retain for their financial services needs.

There are 13 states requiring the notice to include an approximate date (or date range) for the breach, and 38 states without such a requirement.[863] These 38 states account for 70 percent of the U.S. population and 49 million estimated potential customers.[864] For these customers, the final amendments might result in their receiving information they would not have otherwise

---

860 *See* final rule 248.30(a)(4)(iv)(B).

861 *See* ICI Comment Letter 1.

862 *See supra* footnote 210 and accompanying text.

863 *See supra* section IV.C.2.a(2).

864 *See supra* footnote 767.

received. Because 13 states already require that the notice include an approximate date, we expect that the costs will be minimal for the covered institutions that operate nationally. For the covered institutions that do not operate nationally, the final amendments might require them to adapt their procedures to include additional information in the notices to customers.

The third item required by the final amendments is "contact information sufficient to permit an affected individual to contact the covered institution to inquire about the incident, including the following: a telephone number (which should be a toll-free number if available), an email address or equivalent method or means, a postal address, and the name of a specific office to contact for further information and assistance." [865] One commenter disagreed with this proposed requirement, stating that it was unclear what purpose or benefit this requirement would have for the affected individuals and adding that it would place significant burdens on the internal operations of the covered institution.[866] Another commenter also disagreed with this proposed requirement, stating that covered institutions should have flexibility in determining the contact information to provide, based on how they normally interact with their customers, and suggesting that the final amendments only require one of the listed contact methods.[867] The requirement to include multiple contact methods provides valuable options for affected customers, who may have differing preferences and aptitudes in their use of contact methods.[868] We do not expect that this requirement will overly burden covered institutions, even for those

---

865 Final rule 248.30(a)(4)(iv)(C).

866 *See* CAI Comment Letter.

867 *See* SIFMA Comment Letter 2.

868 In addition, the final amendments will not preclude a covered institution from providing the contact information of a third-party service provider. *See supra* footnote 211.

institutions that will need to adapt their processes to the new requirements.[869] In addition, nothing in this requirement prevents a covered institution from providing additional contact methods.

The final amendments also require the notice to include a recommendation that the customer review account statements and immediately report suspicious activity to the covered institution (if the individual has an account with the covered institution); an explanation of what a fraud alert is and how an individual may place one; a recommendation that the individual periodically obtain credit reports; an explanation of how the individual may obtain a credit report free of charge; and information about the availability of online guidance from the FTC and usa.gov regarding steps an individual can take to protect against identity theft, a statement encouraging the individual to report any incidents of identity theft to the FTC, and the FTC's website address.[870] One commenter supported these proposed requirements, stating that the proposed notice requirements avoided common problems with the content of many data breach notifications, such as confusing language, a lack of details, and insufficient attention to the practical steps customers should take in response.[871] We expect that these additional elements will provide useful information to affected customers regarding potential mitigating actions to take and help ensure that these customers are able to react appropriately to the notice. We expect that while these requirements will impose costs on covered institutions whose notification

---

869 Ten states require the notice to include a phone number as contact information while two states require the notice to include a physical address. *See supra* section IV.C.2.a(2).

870 *See* final rule 248.30(a)(4)(iv)(D) through (H).

871 *See* Better Markets Comment Letter.

process does not already include these elements,[872] these costs will be limited and passed on to the customers.[873] We received no comments opposing these requirements.

The proposed amendments included a provision that would have required the notice to include a description of what has been done by the covered institution to protect the sensitive customer information from further unauthorized access or use. One commenter disagreed with this proposed requirement, stating that it "would be extremely useful to threat actors and not particularly useful to clients."[874] After considering this comment, we have decided to exclude this provision from the final amendments.[875] In addition to reducing the perceived risk of providing a roadmap for threat actors, we expect that this change will accelerate the process of preparing the notice, thereby reducing the associated costs.

The final amendments require that notice must be transmitted by a means designed to ensure that each affected individual can reasonably be expected to receive actual notice in writing.[876] Some commenters discussed the alignment between the requirements of the final amendments and those of existing regulation affecting covered institutions. In particular, one commenter stated that a Federal notification requirement would complicate compliance efforts for covered institutions already complying with similar state laws.[877] On the other hand, another commenter stated that the proposed amendments' alignment with existing requirements would

---

872 Because some states require some of these elements to be included in the notification to affected individuals, we expect that many covered institutions already have procedures similar to those required by the final amendments. *See supra* section IV.C.2.a(2).

873 As discussed above, these costs will represent only a fraction of the policies and procedures costs discussed in section IV.D.1 above. *See supra* footnote 856 and accompanying text.

874 *See* IAA Comment Letter 1.

875 *See supra* section II.A.3.e.

876 *See* final rule 248.30(a)(4)(i). Under the final amendments, the notice can be sent electronically. *See supra* footnote 200 and accompanying text.

877 *See* CAI Comment Letter.

allow covered institutions to leverage existing programs.[878] We analyze here the expected benefits and costs of this provision of the final amendments vis-à-vis the baseline.[879]

We expect that the main benefit of this provision will be to help ensure that customers whose sensitive personal information has been breached receive the required information. We expect that the costs of this provision will be limited for most covered institutions since most states require similar methods of notification.[880] Hence, we expect that most covered institutions will not have to significantly modify their procedures and processes for notice issuance in order to satisfy this provision of the final amendments.

However, we do expect some benefits in some instances. First, 26 states allow a notice to be made over the telephone.[881] While 7 of these states require direct contact with the affected individuals when the notice is given using this method, 19 do not have such requirements.[882] We expect that for the 21 million potential customers residing in the 19 states allowing for telephonic notices but without such requirements,[883] receiving a written notice may result in clearer information and in a higher likelihood of taking appropriate mitigating actions.

Second, many states allow for electronic notifications. While most of these states require that this be done only under certain conditions that are similar to the final amendments' conditions, some states have conditions that are significantly looser. The final amendments provide that the notice can be provided through electronic means to customers who have agreed

---

878 *See* FSI Comment Letter.

879 *See supra* section IV.C.2.a(2).

880 *See id*.

881 *See id*.

882 *See supra* footnote 568 and accompanying text.

883 *See supra* footnote 767.